Richtlinie: IAM, Endgeräte & Wechselmedien

Dokumenten-ID: SEC-IAM-END-02 | Version: 1.4 | Zielgruppe: Alle Mitarbeitenden (Min. Role L1)

§ 1 Zugriffskontrolle (Least Privilege) und Privileged Access

Der Zugriff auf sämtliche IT-Systeme, Applikationen und Datenbestände des Unternehmens richtet sich strikt nach dem Need-to-Know-Prinzip sowie dem Grundsatz der minimalen Rechtevergabe (Least Privilege). Jede Berechtigungszuweisung erfordert eine dokumentierte Freigabe durch den jeweiligen Data Owner im IAM-Workflow-System. Administratoren erhalten für privilegierte Tätigkeiten ein dediziertes Zweitkonto (Admin-Account), das strikt vom regulären E-Mail- und Office-Konto getrennt ist. Alle privilegierten Zugriffe werden über das zentrale Privileged Access Management (PAM) aufgezeichnet und müssen vierteljährlich (alle **90 Tage**) durch den CISO rezertifiziert werden.

§ 2 Passwortkomplexität, Wechselintervalle und Kontosperrung

Abweichend von älteren Entwürfen gilt für Standard-Benutzerkonten im Rahmen dieser Endgeräte-Richtlinie: Passwörter müssen eine Mindestlänge von **12 Zeichen** aufweisen und zwingend Groß- und Kleinbuchstaben, Ziffern sowie Sonderzeichen kombinieren. Zudem müssen alle Benutzerpasswörter regelmäßig alle **60 Tage** geändert werden; die Passwort-Historie blockiert die letzten **12 Passwörter**. Nach **3 fehlgeschlagenen Anmeldeversuchen** in Folge wird das Benutzerkonto automatisch für **30 Minuten** gesperrt. Das Aufschreiben von Passwörtern auf Haftnotizen, unter Tastaturen oder sichtbar im Homeoffice (z. B. am Monitor oder Kühlschrank) stellt einen schweren Sicherheitsverstoß dar.

§ 3 Umgang mit Wechseldatenträgern (USB-Sticks) und Schnittstellen

Die Nutzung privater oder nicht registrierter USB-Sticks, externer Festplatten und SD-Karten an dienstlichen Endgeräten ist ausnahmslos **verboten** und wird über die Endpoint-Protection-Richtlinie technisch blockiert. Das Kopieren von Unternehmensdaten, Quellcode oder Passwörtern auf private USB-Speichermedien ist strengstens untersagt. Sofern für den Datenaustausch mit Kunden oder Behörden ein physischer Datenträger zwingend erforderlich ist, darf ausschließlich ein vom IT-Service-Desk ausgegebener, hardwareverschlüsselter Unternehmens-USB-Stick (AES-256 Bit, Seriennummer im Asset-Register erfasst) verwendet werden.

§ 4 Mobile Endgeräte, Clean Desk und Arbeiten im öffentlichen Raum

Dienstliche Laptops und Smartphones müssen mit vollständiger Festplattenverschlüsselung (BitLocker / FileVault) und einer automatischen Bildschirmsperre nach maximal **5 Minuten** Inaktivität ausgestattet sein. Beim Verlassen des Arbeitsplatzes – auch im Homeoffice, sofern Dritte oder Familienangehörige Zugang zum Raum haben – ist der Bildschirm sofort manuell zu sperren (Clean-Desk- & Clear-Screen-Policy).

Für das mobile Arbeiten auf Reisen (z. B. im Zug, Bahnhof oder Café) gilt: Das Bearbeiten interner Dokumente ohne aktive VPN-Verbindung ist für maximal **2 Stunden pro Tag** gestattet, sofern lokal im Offline-Modus gearbeitet wird. Für das Abrufen von E-Mails oder den Zugriff auf vertrauliche Daten ist jedoch zwingend ein Sichtschutzfilter (Privacy Screen) sowie das Unternehmens-VPN zu aktivieren.

§ 5 Meldepflicht bei Geräteverlust und Sanktionskatalog

Der Verlust oder Diebstahl eines dienstlichen Laptops, Smartphones, Hardware-Tokens (FIDO2) oder eines USB-Datenträgers muss **unverzüglich, spätestens jedoch innerhalb von 1 Stunde** nach Bemerken telefonisch an den IT-Service-Desk und das CISO-Office gemeldet werden, damit eine sofortige Fernlöschung (Remote Wipe) eingeleitet werden kann. Bei Verstößen gegen diese Richtlinie greift folgender arbeitsrechtlicher Maßnahmenkatalog:

Art des Sicherheitsverstoßes	Schweregrad	Sofortmaßnahme IT / CISO	Disziplinarische / Arbeitsrechtliche Folge
Offenes Passwort (Notizzettel am Arbeitsplatz / Homeoffice)	Mittel	Erzwungener Passwort-Reset, Pflicht-Nachschulung	Mündliche Verwarnung durch Vorgesetzten; Vermerk im Schulungsregister.
Anschluss privater USB-Sticks ohne Datenabfluss	Hoch	USB-Port-Sperre, forensischer Malware-Scan des Geräts	Formelle schriftliche Ermahnung durch HR; Information des Bereichsleiters.
Kopieren von Passwörtern/Kundendaten auf privaten USB-Stick (inkl. Verlust im Zug)	Kritisch	Sofortige Kontosperrung, Passwort-Rotation, DSGVO/NIS-2 Vorfallprüfung	**Arbeitsrechtliche Abmahnung** bis hin zur **fristlosen Kündigung** sowie Schadensersatzprüfung bei grober Fahrlässigkeit.
Verspätete Verlustmeldung (> 1 Stunde bei Laptop/Token)	Hoch	Remote Wipe, Sperrung aller aktiven Sitzungs-Tokens	Schriftliche Abmahnung; Entzug der Berechtigung für mobiles Arbeiten.

> **Revisionshinweis (Konfliktpotenzial):** Die in § 2 genannten Vorgaben (12 Zeichen Mindestlänge, 60 Tage Wechselpflicht) sowie die 2-Stunden-Offline-Ausnahme im Zug (§ 4) entstammen dem Legacy-Endgerätestandard und stehen im Widerspruch zur neuen *Passwort-Richtlinie v3/v4* (14 bzw. 15 Zeichen, kein periodischer Wechsel) sowie der *Mobile-Work-Policy v2*.